

01em

0.01em

Fundamentals of Information Systems Security

ISO/IEC 27001:2022 Compliance Checklist

A Comprehensive Guide to ISMS Implementation and Certification

Version: 1.0	Standard: ISO/IEC 27001:2022
Controls: 93 Annex A Controls	Status: Current

Contents

1	Introduction to ISO/IEC 27001	2
1.1	Overview	2
1.2	Key Changes in the 2022 Revision	2
1.3	The Four Annex A Themes	2
2	ISO 27001 Implementation Checklist	3
2.1	Phase 1: Initiation and Planning	3
2.2	Phase 2: Context Establishment	3
2.3	Phase 3: Risk Assessment and Treatment	4
2.4	Phase 4: ISMS Framework Development	4
2.5	Phase 5: Implementation and Operation	5
2.6	Phase 6: Monitoring and Review	5
2.7	Phase 7: Continual Improvement	6
2.8	Phase 8: Certification Audit	6
3	Annex A Control Categories	7
3.1	Organizational Controls (37 Controls)	7
3.2	People Controls (8 Controls)	7
3.3	Physical Controls (14 Controls)	7
3.4	Technological Controls (34 Controls)	8
3.5	New Controls in ISO 27001:2022	8
4	Common Implementation Challenges	8
4.1	Top Management Commitment	8
4.2	Scope Management	9
4.3	Stakeholder Engagement	9
5	References	9

1 Introduction to ISO/IEC 27001

1.1 Overview

ISO/IEC 27001 is the internationally recognized standard for information security management systems (ISMS). Achieving ISO 27001:2022 certification is a strategic milestone that demonstrates an organization's commitment to information security[reference:50]. This certification not only enhances security posture but also builds trust with clients and stakeholders[reference:51].

1.2 Key Changes in the 2022 Revision

The 2022 revision of ISO 27001 introduced several significant changes[reference:52][reference:53]:

- Restructured Annex A from 114 controls across 14 domains to 93 controls across 4 themes[reference:54]
- 35 controls remain unchanged
- 23 controls have been renamed
- 57 controls have been merged into 24 controls
- One control has been split into two[reference:55]
- 11 new controls have been added[reference:56]

1.3 The Four Annex A Themes

The 93 controls in Annex A are organized into four themes[reference:57]:

Theme	Number of Controls	Focus Areas
Organizational Controls	37	Policies, procedures, roles, and responsibilities[reference:58]
People Controls	8	Employee security, awareness, and training[reference:59]
Physical Controls	14	Physical security, facilities, and equipment
Technological Controls	34	Technical security measures and solutions[reference:60]

2 ISO 27001 Implementation Checklist

2.1 Phase 1: Initiation and Planning

Phase 1: Initiation and Planning

1. Secure Top Management Commitment

- Secure commitment and support from top management[reference:61]
- Ensure resources and authority are allocated to the ISMS project[reference:62]
- Establish an ISMS project team with defined roles and responsibilities[reference:63]
- Include representatives from various departments[reference:64]

2. Develop Project Plan

- Develop a project plan outlining the scope, objectives, timelines, and resources required[reference:65]
- Create a well-structured project plan as the backbone of a successful ISMS implementation[reference:66]

3. Training and Awareness

- Train the project team on ISO 27001:2022 requirements[reference:67]
- Raise awareness among all employees about the importance of information security[reference:68]

2.2 Phase 2: Context Establishment

Phase 2: Context Establishment

1. Understand the Organization (Clause 4.1)

- Analyse internal and external issues affecting the ISMS[reference:69]
- Consider the business environment, regulatory landscape, and internal processes[reference:70]

2. Identify Interested Parties (Clause 4.2)

- Identify and document the needs and expectations of interested parties[reference:71]
- Include customers, suppliers, regulators, and employees[reference:72]

3. Define the ISMS Scope (Clause 4.3)

- Define the scope of the ISMS, including boundaries and applicability[reference:73]
- Include locations, assets, technologies, and processes[reference:74]

2.3 Phase 3: Risk Assessment and Treatment

Phase 3: Risk Assessment and Treatment

1. Establish Risk Assessment Methodology

- Define risk acceptance criteria and risk assessment methodology[reference:75]
- Determine the approach for identifying and analyzing risks

2. Conduct Risk Assessment

- Identify risks to the confidentiality, integrity, and availability of information[reference:76]
- Analyze and evaluate risks using qualitative or quantitative methods

3. Risk Treatment

- Select appropriate risk treatment options (accept, mitigate, transfer, avoid)
- Map risks to Annex A controls[reference:77]
- Develop Statement of Applicability (SoA)[reference:78]

2.4 Phase 4: ISMS Framework Development

Phase 4: ISMS Framework Development

1. Develop Information Security Policies (Clause 5.2)

- Create a top-level information security policy
- Establish supporting policies for specific areas

2. Define Roles and Responsibilities (Clause 5.3)

- Assign information security roles and responsibilities
- Establish accountability for security controls

3. Document Procedures

- Develop procedures for key processes
- Ensure documentation is controlled and maintained

2.5 Phase 5: Implementation and Operation

Phase 5: Implementation and Operation

1. Implement Security Controls (Clause 6.1.3)

- Implement the controls identified in the Statement of Applicability[reference:79]
- Turn each control into a simple operating process[reference:80]
- Define how the control works in your organization[reference:81]

2. Implementation Areas

- Implementation typically spans four areas[reference:82]
- Technical controls (firewalls, encryption, access control)
- Organizational controls (policies, procedures, training)
- Physical controls (facility security, environmental controls)
- People controls (awareness, behavior, culture)

3. Train Employees on Policies and Procedures[reference:83]

- Develop and deliver security awareness training
- Ensure employees understand their responsibilities

2.6 Phase 6: Monitoring and Review

Phase 6: Monitoring and Review

1. Monitor and Measure (Clause 9.1)

- Monitor the effectiveness of security controls
- Track and report on security performance

2. Internal Audit (Clause 9.2)

- Conduct internal audits at planned intervals[reference:84]
- Verify compliance with ISO 27001 requirements

3. Management Review (Clause 9.3)

- Conduct regular management reviews of the ISMS
- Review security performance, incidents, and risks

2.7 Phase 7: Continual Improvement

Phase 7: Continual Improvement

1. **Corrective Actions (Clause 10.1)**
 - Identify and address non-conformities
 - Implement corrective actions to prevent recurrence
2. **Continual Improvement (Clause 10.2)**
 - Continuously improve the effectiveness of the ISMS
 - Update risk assessments and controls as needed

2.8 Phase 8: Certification Audit

Phase 8: Certification Audit

1. **Find an Accredited Auditor[reference:85]**
 - Select an accredited certification body
 - Schedule the certification audit
2. **Stage 1 Audit**
 - Review of ISMS documentation[reference:86]
 - Verify that the ISMS is properly designed
3. **Stage 2 Audit**
 - Review implementation of controls[reference:87]
 - Assess functionality, suitability, and effectiveness[reference:88]
4. **Certification Decision**
 - Receive certification decision from auditor
 - Address any non-conformities identified

3 Annex A Control Categories

3.1 Organizational Controls (37 Controls)

Organizational controls address the policies, procedures, and management of information security[reference:89]. Key areas include:

Control Area	Description
Information Security Policy	Development and communication of security policies
Roles and Responsibilities	Assignment of security roles and accountabilities
Segregation of Duties	Separation of conflicting duties
Competence and Awareness	Training and awareness programs
Incident Management	Procedures for handling security incidents
Business Continuity	Continuity planning and testing
Supplier Relationships	Managing third-party security risks
Compliance	Monitoring compliance with legal and regulatory requirements

3.2 People Controls (8 Controls)

People controls address the human aspects of information security[reference:90]:

- Screening and background checks
- Terms and conditions of employment
- Information security awareness and training
- Disciplinary process for security violations
- Responsibilities after termination
- Remote working policies
- Confidentiality and non-disclosure agreements

3.3 Physical Controls (14 Controls)

Physical controls address the physical security of assets and facilities:

- Physical security perimeters
- Physical entry controls
- Securing offices, rooms, and facilities
- Working in secure areas
- Equipment siting and protection
- Cabling security
- Equipment maintenance
- Secure disposal of equipment

3.4 Technological Controls (34 Controls)

Technological controls address the technical aspects of information security[reference:91]:

- Access control policies
- User authentication and registration
- Privileged access management
- Password management
- Malware protection
- Network security controls
- Application security
- Cryptographic controls
- Monitoring and logging
- Vulnerability management
- Technical compliance review

3.5 New Controls in ISO 27001:2022

The 2022 revision introduced 11 new controls[reference:92][reference:93]:

1. Threat intelligence (5.7)[reference:94]
2. Information security for the use of cloud services[reference:95]
3. Information security for the use of mobile devices
4. Configuration management
5. Monitoring activities
6. Physical security monitoring
7. Workplace privacy
8. Data masking
9. Data leakage prevention
10. Web filtering
11. Secure coding

4 Common Implementation Challenges

4.1 Top Management Commitment

- Gaining full buy-in from top management can be difficult[reference:96]
- Communicate the long-term benefits of ISO 27001 certification clearly[reference:97]
- Demonstrate the business value of certification

4.2 Scope Management

- Managing scope creep can be challenging[reference:98]
- Regularly review and adjust the project plan as necessary[reference:99]
- Maintain focus on the defined ISMS scope

4.3 Stakeholder Engagement

- Balancing conflicting interests of different stakeholders can be challenging[reference:100]
- Prioritize stakeholders based on their impact on the ISMS[reference:101]
- Ensure regular communication with all stakeholders

5 References

- ISO/IEC 27001:2022, Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements
- ISO/IEC 27002:2022, Information Security, Cybersecurity and Privacy Protection — Information Security Controls
- ISO/IEC 27003:2017, Information Technology — Security Techniques — Information Security Management Systems — Guidance
- ISO/IEC 27004:2016, Information Technology — Security Techniques — Information Security Management — Monitoring, Measurement, Analysis and Evaluation
- ISO/IEC 27005:2022, Information Security, Cybersecurity and Privacy Protection — Guidance on Managing Information Security Risks